



GRUPO 13



Miembros del Grupo:

Mario Martín Feliz (Portavoz)

Mario Bote Sánchez

Oscar Cardeña Gutiérrez

Índice

- **Introducción**
- **Metodología**
- **Hallazgos**
 - Puertos abiertos
 - Configuración DNS incorrecta
 - Archivo descargable expuesto
 - Uso de Apache Struts
 - Falla de validación en carga de archivos
 - Ejecución remota de comandos
 - Escalada de acceso
- **Impacto**
- **Recomendaciones**
- **Conclusiones**

Informe Profesional de Auditoría – Strutted.

INFORME DE AUDITORÍA DE SEGURIDAD

Cliente: Empresa simulada (www.strutted.htb)

Fecha: [Fecha de auditoría]

Auditor: Grupo13 Analytics

1. INTRODUCCIÓN.

Se ha llevado a cabo una auditoría de seguridad sobre el servidor web de la empresa "strutted.htb", alojado en una instancia Linux con servicios públicos visibles en los puertos 22 (SSH) y 80 (HTTP). El objetivo ha sido identificar vulnerabilidades que puedan comprometer la confidencialidad, integridad y disponibilidad del sistema.

2. METODOLOGÍA.

La auditoría se ha desarrollado en las siguientes fases:

- Reconocimiento activo de servicios y sistema operativo.
- Análisis de configuraciones visibles.
- Revisión de código y componentes descargables.
- Identificación de vulnerabilidades.
- Explotación controlada.
- Obtención de acceso no autorizado.
- Recomendaciones.

3. HALLAZGOS.

3.1. Puertos abiertos:

Se identificaron los siguientes puertos accesibles desde internet:

- 22/tcp (SSH): OpenSSH
- 80/tcp (HTTP): Nginx

3.2. Configuración DNS incorrecta:

La resolución DNS del dominio requería configuración local, lo que indica una mala implementación de virtual hosting.

3.3. Archivo descargable expuesto:

El archivo strutted.zip accesible desde la raíz del servidor contenía información sensible, incluyendo un archivo tomcat.xml con credenciales.

3.4. Uso de Apache Struts:

Se detectó que la aplicación web utiliza el framework Apache Struts, vulnerable a CVE conocido que permite ejecución remota de código mediante la manipulación del campo de subida de archivos.

3.5. Falla de validación en carga de archivos:

Mediante el uso de Burp Suite, se determinó que al cambiar el nombre del campo de subida a Upload se activaba un interceptor en Struts, permitiendo la subida de una webshell JSP sin validación.

3.6. Ejecución remota de comandos:

La webshell permitió ejecutar comandos como `whoami`, `hostname -l` y otros, confirmando que el sistema es vulnerable a ejecución remota no autenticada.

3.7. Escalada de acceso:

Se obtuvo una reverse shell usando un payload bash transferido mediante `wget`. A través de la shell, se accedió a archivos internos, incluyendo tomcat-users.xml con credenciales válidas para SSH del usuario james.

4. IMPACTO.

La vulnerabilidad explotada permitió acceso total al sistema, incluida la obtención de la flag de usuario. El atacante puede comprometer la confidencialidad de la información, pivotar a otros sistemas y provocar daño reputacional y económico.

5. RECOMENDACIONES.

- * Eliminar archivos accesibles públicamente que contengan información sensible.
- * Implementar controles estrictos en la validación de campos en formularios de subida.
- * Aplicar actualizaciones de seguridad al framework Apache Struts.
- * Monitorizar logs y accesos a recursos críticos.
- * Realizar pruebas de penetración de forma periódica.

6. CONCLUSIONES.

El sistema evaluado presenta vulnerabilidades críticas que permiten comprometer la infraestructura con acceso remoto y persistente. Se recomienda actuar con urgencia para mitigar los riesgos detectados.